

Authentication, Identity and Access Management

Florence Love Nkosi, CISA|CEH| CEI

ACCESS CONTROLS

- **Access controls** is a system which enables an authority to control access to areas and resources in a given physical facility or computer-based information system.
- **Access control** is the fundamental requirement for security. Without access controls there can be no security.
- Access controls apply to files on a file system and to services provided by remote servers. Access should be provided on a need to-know basis.
- If we are too lax in our treatment of access rights, we can fall foul of intrusion
- Within this broad definition, there are two areas of primary interest, namely, **authentication** and authorization.

Three A's of Information Security

- Security is about differentiating among authorized accesses and unauthorized accesses
  - Confidentiality, Integrity, Availability all require this
- Authentication
  - Figures out who is accessing
- Access control
  - Ensure only authorized access are allowed
- Auditing
  - Record what is happening, to identify attacks later and recover

IAAA (Identification and Authentication, Authorization and Accountability)

- **Identification : who are you?**
  - • Your name, username, ID number, employee number, SSN etc.
  - •"I am Thor".
- **Authentication :** Authentication is the process of determining whether a user (or other entity) should be allowed access to a system.
  - • "Prove you are Thor". – Should always be done with multi-factor authentication!
  - • Something you know - Type 1 Authentication (passwords, pass phrase, PIN, etc.).
  - • Something you have - Type 2 Authentication (ID, passport, smart card, token, cookie on PC, etc.).
  - • Something you are - Type 3 Authentication (and Biometrics) (Fingerprint, iris scan, facial geometry, etc.).

IAAA (Identification and Authentication, Authorization and Accountability)

- **Authorization: Are you allowed to do that?**
  - What are you allowed to access?
  - We use Access Control models, what and how we implement depends on the organization and what our security goals are.
- **Accountability (also often referred to as Auditing)**
  - Trace an Action to a Subject's Identity:
  - Prove who/what a given action was performed by (non-repudiation)

Identity and access management

- Identity and access management refers to the policies, processes, and technologies that establish user identities and enforce rules about their to digital resources
- IAM products provide IT managers with tools and technologies for controlling user access to critical information within an organization.
- All information processing entities must be uniquely identified and authenticated. This is primarily required for accountability, but is also implicitly required in confidentiality and integrity protection mechanisms for information at the processing level.

Authentication

- Authentication is Verifying the person's credentials to be sure that they are genuine and the user actually is who s/he claims to be.
- Authentication services provided on a network by a dedicated authentication, authorization, and accounting (AAA)

Authentication

- Authentication establishes a level of confidence that the identity provided (e.g. username) is authentic.
- Most authentication methods today rely on one or more of the following factors:
  - Something you know - Password
  - Something you have - a token
  - Something you are - Biometric access i.e finger scanner

Authentication

- A password is an example of "**something you know**". To establish a level of trust it must be something that ONLY the user knows.
- The "**something you have**" factor requires the user to be in possession of something. This "something" is usually referred to as a token. A token is typically, but not necessarily, a hardware device that has been issued to the user for the purposes of authentication i.e Token
- The "**something you are**" factor refers to some form of biometric authentication, based on a measurement of some personal characteristics (which may or may not be physical) i.e scanning your finger or palm

Types of Authentications Methods in security

- Single Factor authentication
- Two-factor authentication
- Multi –factor authentication
- Single sign on

Single factor Authentication

- Single-factor authentication (SFA) is a process for securing access to a given system, such as a network or website, that identifies the party requesting access through only one category of credentials.
- This is "something a user knows." The most recognized type of one-factor authentication method is the password.

Two factor Authentication

- In addition to the first factor, the second factor is "something a user has."
- Examples of something a user has are a fob that generates a pre-determined code, a signed digital certificate or even a biometric such as a fingerprint.
- The most recognized form of two-factor authentication is the ubiquitous RSA SecurID fob.

Multi-factor Authentication

- A Multi-factor authentication strategy is one that verifies users' identities using multiple methods of authentication.
- Multi-factor authentication uses a combination of the following factors: something you know, something you have and something you are.
- For example, a user could input their username and password, which then directs them to a one-time emailed link or security code.
- This way, even if a hacker is able to determine the user's login credentials, they would meet another wall requiring them to have access to the user's email account as well. If they're unable to verify their identity using this additional authentication method, they'll be denied access to the account.

Multi-factor Authentication



Strong authentication

- Strong authentication is associated with two-factor authentication or more generally multi-factor authentication.
- Two-factor authentication (TFA) means using two independent authentication methods based on two independent authentication factors (e.g. password + value from physical token).
- This is in order to increase the assurance that the user has been authorized to access secure systems and to improve protection in a way that the compromise of either one of the factors on its own would not be sufficient for an attacker to gain access

Single Sign on (SSO)

- **Single sign**-on (**SSO**) is a session and user authentication service that permits a user to use one set of **login** credentials -- for **example**, a name and password -- to access multiple applications.
- For example, logging in to your Google account once will allow you to access Google applications such as Google Docs, Gmail, and Google Drive.

How does SSO work ?



How does SSO work ?



Advantages of SSO :

These are advantages for users, for businesses.

- **For Users –**
  - Risk of access to 3rd party sites are mitigated as the website database do not store the user's login credentials.
  - Increased convenience for users as they only need to remember and key in login information once.
  - Increased security assurance for users as website owners do not store login credentials.
- **For Businesses –**
  - Increase customer base and satisfaction as SSO provides lower barrier to entry and seamless user experience.
  - Reduce IT costs for managing customer's username and passwords

Disadvantages of SSO :

- Increased security risk if login credentials are not securely protected and are exposed or stolen as adversaries can now access many websites and applications with a single credential.
- Integration problem. The SSO cannot be proven to be integrated with all the system components and could require complex design to do so

•System evolution. Adding new components to the system can introduce incompatibility with the SSO features.

Passwords

- A password is a secret text that is supposed to be known only to a user. In password based system, each user is assigned a valid username and password by the system administrator.
- Passwords are something you Know

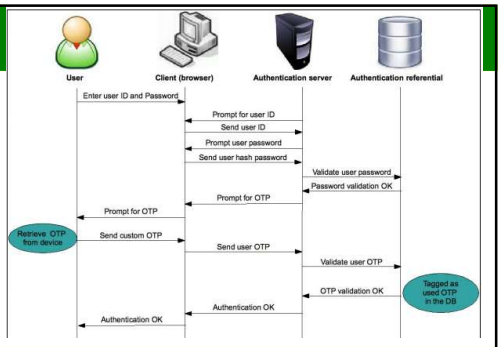
One Time Passwords

- In One-Time Password system, a unique password is required every time user tries to login into the system.
- The principle of this authentication method is to use a password that is valid for only one session or one transaction- this password is called One Time Password (OTP).
- The OTP is transmitted by a chosen way to the user in order to represent a “something you have” authentication information.
- Combined with another authentication method, it is considered as strong two-factor authentication.
- Once a one-time password is used, then it cannot be used again.

One Time Passwords

- Unlike the basic password authentication, OTP method is not vulnerable to replay attacks. This means that, if a potential intruder manages to record an OTP that was already used to log into a service or to conduct a transaction, he or she will not be able to abuse it since it will be no longer valid.
- To insure the uniqueness of the used OTP, they are generated using one of the following methods:
  - Randomly, the set of random generated passwords is known by the authentication server. Every time a password is used, it is dropped off from the authorized passwords set on the authentication server.
  - Based on time synchronization between the authentication server and the client providing the password (OTPs are valid only for a short time period).
  - Using a challenge-response mechanism.

One Time Passwords



Something you Have

- Smartcards or other hardware tokens can be used for authentication.
- Such authentication is based on the "something you have" principle.
- **Tokens, Cards, and Cell Phones are categorized as something you have, commonly used together with something you have.**

Tokens

- A **token** is typically a small device (usually one that can be affixed to a keychain) with a window display, a token authenticates a user by requesting them to present something they have i.e a token number.
- Security tokens are special devices that possessed by the user. Semantically, the devices dedicated to the generation of OTPs are commonly called “token”.
- Synchronized password using time as a common denominator. The OTP changes at regular intervals, for example once a minute.
- The authentication server and the tokens are synchronized to Universal Time.
- To log into the system, users enter their password and the unique value generated by their token. They will be granted access to the system if their OTP and the one generated on the server side are the same

Hardware Tokens

- Hardware tokens are physical devices offering the functionality of OTP generation.
- The token model defines the type of OTP that can be generated.
- Many vendors offer a wide range of OTP-generating tokens of different shapes and sizes, and many offer custom branding options to print for example the company logo on the token.
- The simplest tokens are suitable for user authentication only with a simple button to start a generating routine with some display capability to show the generated key number.
- More advanced tokens incorporate keypad to allow entry of PIN code or challenge, making them suitable for transaction authenticatio



Hardware Tokens

Advantages

- Users don't need to remember complex passwords.
- The solution can be used both for login and transaction authentication.
- The solution is computing platform and application independent.
- The solution offers portability advantage so the users can perform authentication from remote location, the small token size allowing it to be carried every where.

Disadvantages

- Involves additional costs, such as the cost of the tokens and replacement fees (batteries ...).
- Users need to always carry the token with them, which is an additional unusual device besides mobile phones, laptops etc
- Users need multiple tokens for multiple Web sites and devices.

Software Tokens

- Also called virtual tokens, these are software implementations of the hardware token functionality designed for installation on computers (hard drive), USB devices, PDA's and mobile devices such as BlackBerry and iPhone.
- Virtual tokens work by sharing the token generation process between the internet website and the user's computer.
- This requires the user to launch the software token application, generate an OTP and then cut-and-paste this into the password field
- Software tokens can be issued and revoked as often as required, without additional cost or need to remove or recover the token from the client machine.

Software tokens

Advantages

- Virtual token can be held on multiple media, such as a hard disk, floppy disk, and flash drive.
- The solution does not require the distribution and use of additional hardware, so the solution can have more user acceptance.
- If not explicitly revoked, software token does not expire for example because of batteries.

Disadvantages

- Software token requires some amount of user training.
- Virtual token need to be deployed in controlled environment.
- The solution requires reinstallation and configuration in case there is an operating system corruption or problem.
- It needs a protected and personal environment (e.g., should not be used from a public workstation).
- The virtual token is platform and application dependent (OS installed on, the web application it can be integrated with).

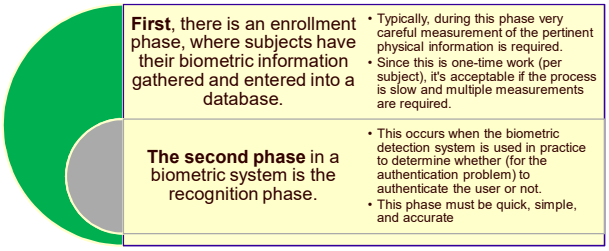
Biometrics –Something you are

- Biometrics represent the "something you are" method of authentication or, as Schneider so aptly puts it, "you are your key"
- In the information security arena, biometrics are seen as a more secure alternative to passwords.
- For biometrics to be a practical replacement for passwords, cheap and reliable systems are needed.
- Today, usable biometric systems exist, including laptops using thumbprint authentication, palm print systems for secure entry into restricted facilities, the use of fingerprints to unlock car doors, and so on.

Characteristic of Biometric

- **Universal** — A biometric should apply to virtually everyone. In reality, no biometric applies to everyone. For example, a small percentage of people do not have readable fingerprints.
- **Distinguishing** — A biometric should distinguish with virtual certainty. In reality, we can't hope for 100% certainty, although, in theory, some methods can distinguish with very low error rates.
- **Permanent** — Ideally, the physical characteristic being measured should never change. In practice, it's sufficient if the characteristic remains stable over a reasonably long period of time.
- **Collectable** — The physical characteristic should be easy to collect without any potential to cause harm to the subject. In practice, collectability often depends heavily on whether the subject is cooperative or not.
- **Reliable, robust, and user-friendly** — These are just some of the additional real-world considerations for a practical biometric system. Some biometrics that have shown promise in laboratory conditions have subsequently failed to deliver similar performance in practice.

Biometric System phases



First, there is an enrollment phase, where subjects have their biometric information gathered and entered into a database.

- Typically, during this phase very careful measurement of the pertinent physical information is required.
- Since this is one-time work (per subject), it's acceptable if the process is slow and multiple measurements are required.

The second phase in a biometric system is the recognition phase.

- This occurs when the biometric detection system is used in practice to determine whether (for the authentication problem) to authenticate the user or not.
- This phase must be quick, simple, and accurate

Biometric Examples

- Fingerprints
- Hand Geometry
- Iris Scan

Challenges of Biometric authentication

- The **central issue** is that **biometric authentication** technologies pose privacy and security **concerns**: once **biometric** data has been compromised, there is no way to undo the damage.
- For a compromised password, you simply change it; for a **fingerprint**, ear image, or iris scan, you're stuck with the compromised **biometric**.

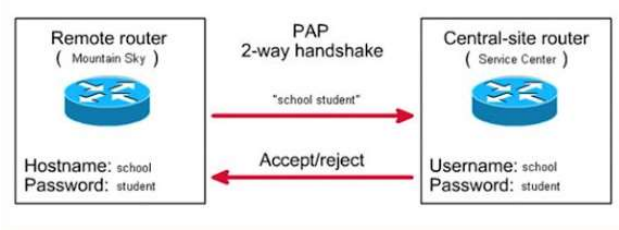
Authentication Protocols

- Authentication protocols are the designated rules for interaction and verification that endpoints (laptops, desktops, phones, servers, etc.) or systems use to communicate.
- Network authentication protocols are well defined, industry standard ways of confirming the identity of a user when accessing network resources.
- There are two basic authentication mechanisms:
  1. Password Authentication Protocol
  2. Challenge Handshake Authentication

PAP

- Short for **Password Authentication Protocol**, the most basic form of authentication, in which a user's name and password are transmitted over a network and compared to a table of name-password pairs.
- The username and password are sent in plain text, there is no encryption or protection, If login credentials are accepted, the connection is allowed
- When PAP authentication is requested by one end of the link during the link establishment phase, the other end must respond with a valid and recognized identifier and password pair. If it fails to respond, or if either the identifier or password are rejected, authentication fails and the link is closed.
- While common, PAP is the least secure protocol for validating users, due mostly to its lack of encryption.

PAP



CHAP

- CHAP is an identity verification protocol that verifies a user to a given network with a higher standard of encryption using a three-way exchange of a "secret."
- The Challenge-Handshake Authentication Protocol (CHAP) provides password authentication on initial link establishment, based on a three-way handshake mechanism.
- Challenge-Handshake Authentication Protocol(CHAP) is a more secure procedure for connecting to a system than the Password Authentication Procedure (PAP).

CHAP

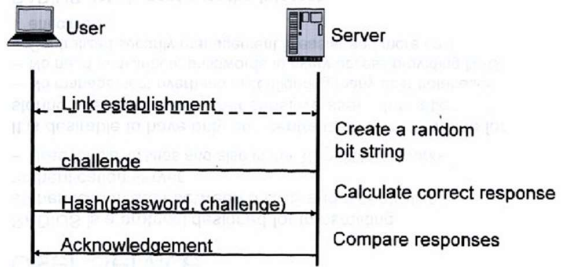
- When CHAP authentication is requested by one end of the link, it generates a challenge message that includes a **challenge value**, which is calculated from the CHAP secret.
- The other end must respond to the challenge message with a **response value**, which is calculated from the challenge value received, and the common secret.
- If it fails to respond, or if the response does not correspond to that expected by the authenticator, the link is closed.

CHAP

CHAP uses a three-way handshake after establishing a link between the client and the server.

1. A challenge message is sent from the authenticating server to the client.
2. The client replies with a value computed using a one-way hash function
3. When the authenticating server receives the response it checks the value against its own calculation of the expected hash value. If the value matches, the server responds telling the user it has been successful.

CHAP



CHAP



Tools and Protocols for Authentication

- Tools and protocols that are commonly used in companies and organizations for authentication and authorization.
- These are:
  - Kerberos
  - RADIUS

Kerberos

- Kerberos is a protocol for authenticating service requests between trusted hosts across an untrusted network, such as the internet, developed by MIT.
- Kerberos uses symmetric key cryptography and requires trusted third-party authorization to verify user identities.
- Its name refers to a character from Greek mythology: Cerberus is a three-headed dog responsible for guarding the entrance of the underworld. Kerberos had a snake tail and a particularly bad temper and, despite one notable exception, was a very useful guardian.
- In a similar way, Kerberos guards a network, allowing entry only to those who are authenticated.
- But in the protocol's case, the three heads of Kerberos represent the client, the server, and the Key Distribution Center (KDC).

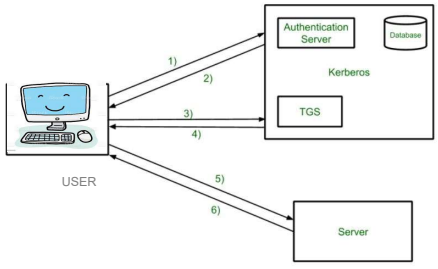
Kerberos

- Kerberos runs as a third-party trusted server known as the Key Distribution Center (KDC). Each user and service on the network is a principal.
- The main components of Kerberos are:
  - **Authentication Server (AS):**
    The Authentication Server performs the initial authentication and ticket for Ticket Granting Service.
  - **Database:**
    The Authentication Server verifies access rights of users in database.
  - **Ticket Granting Server (TGS):**
    The Ticket Granting Server issues the ticket for the Server

Kerberos

- Kerberos is typically used when a user attempts to access a network service and that service requires authentication.
- The user is provided a ticket that is issued by the Kerberos authentication server, this ticket contains information linking it to the user.
- The user presents this ticket to the network for a service. The service then examines the ticket to verify the identity of the user. If the user is verified, he is then accepted.

HOW KERBEROS WORK



HOW KERBEROS WORK

- **Step-1:**
  User logon and request services on host. Thus user request for ticket-granting-service.
- **Step-2:**
  Authentication Server verifies user's access right using database and then gives ticket-granting-ticket and session key. Results are encrypted using Password of user.
- **Step-3:**
  Decryption of message is done using the password then send the ticket to Ticket Granting Server. The Ticket contain authenticators like user name and network address.
- **Step-4:**
  Ticket Granting Server decrypts the ticket send by User and authenticator verifies the request then creates the ticket for requesting services from the Server.
- **Step-5:**
  User send the Ticket and Authenticator to the Server.
- **Step-6:**
  Server verifies the Ticket and authenticators then generate the access to the service. After this User can access the services.

Kerberos

- Kerberos authentication is currently the default authorization technology used by Microsoft Windows, and implementations of Kerberos exist in Apple OS, FreeBSD, UNIX, and Linux.
- Kerberos is a vast improvement on previous authorization technologies. The strong cryptography and third-party ticket authorization make it much more difficult for cybercriminals to infiltrate your network

RADIUS

- RADIUS, stands for **Remote Authentication Dial In User service**.
- It is a network security protocol that provides sufficient centralized Authentication, Accounting, and Authorization for the users that use and network services.
- RADIUS was developed by Livingston Enterprises, Inc in 1991 as an authentication and accounting protocol. It was later brought into the Internet Engineering Task Force (IETF) standards.
- RADIUS is a protocol for carrying information related to authentication, authorization, and configuration between a Network Access Server that desires to authenticate its links and a shared Authentication Server.

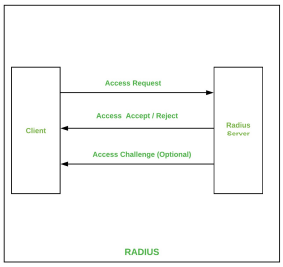
RADIUS

- RADIUS performs three major functions:
  - Authenticates users trying to establish a connection to a network
  - Authorizes users to access requested network services
  - Accounts for the use of those services
- A RADIUS server regulates access to the network by verifying the identity of the users through the login credentials entered.
- For example, a public Wi-Fi network is installed in a university campus. Only those students who have the password can access these networks.
- The RADIUS server checks the passwords entered by the users and permits or denies access as appropriate.

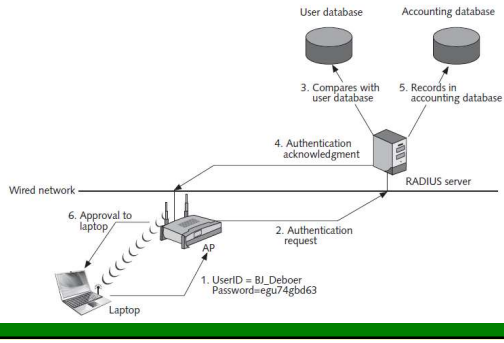
RADIUS

- A RADIUS client is typically a device such as a wireless access point (AP) or dial-up server that is responsible for sending user credentials and connection parameters in the form of a RADIUS message to a RADIUS server.
- The RADIUS server authenticates and authorizes the RADIUS client request, and sends back a RADIUS message response.
- RADIUS clients also send RADIUS accounting messages to RADIUS servers.
- The strength of RADIUS is that messages are never sent directly between the wireless device and the RADIUS server.
- This prevents an attacker from penetrating the RADIUS server and compromising security.

How Radius Works



How Radius Works



How Radius Works

1. The RADIUS process begins by the user sending a request for network access. The user initiates authentication to the Network Access Server (NAS). The user can send the request through browser-based HTTPS connect or from mobile VPN.
2. The server then accepts the request and the authentication process begins. The server requests for and accepts the credentials (username and password) from the user. It creates an access-request message which is then sent to the RADIUS server.
3. The password is received and encrypted through the access-request and sends it to the RADIUS server.
4. The RADIUS server receives the request and checks its authenticity (to check whether it came from a known user or not). If it is not a known client, the request is immediately denied. If the user is found to be suspicious, the server is blocked from sending any further requests.
5. If the client is known, the RADIUS checks the shared code along with the authentication method request. This authentication method should also be a known and allowed method.
6. If the authentication method is an allowed method, the credentials are matched with the database. If the credentials are compatible, the RADIUS server sends a response. But if the credentials do not match, the access is denied. The user is finally authenticated and authorized and will obtain access to the RADIUS client.

How Radius Works

1. A wireless device, called the *supplicant* (it makes an "appeal" for access), sends a request to an AP requesting permission to join the WLAN. The AP prompts the user for the user ID and password.
2. The AP, serving as the *authenticator* that will accept or reject the wireless device, creates a data packet from this information called the *authentication request*. This packet includes information such as identification of the specific AP that is sending the authentication request and the user name and password. For protection from eavesdropping, the AP (acting as a RADIUS client) encrypts the password before it is

How Radius Works

3. When an authentication request is received, the RADIUS server validates that the request is from an approved AP and then decrypts the data packet to access the user name and password information. This information is passed on to the appropriate security user database. This could be a text file, UNIX password file, a commercially available security system, or a custom database.
4. If the user name and password are correct, the RADIUS server sends an authentication acknowledgment that includes information on the user's network system and service requirements.
   - If the username and password are not correct, the RADIUS server sends an authentication reject message to the AP and the user is denied access to the network. To ensure that requests are not responded to by unauthorized persons or devices on the network, the RADIUS server sends an authentication key, or signature, identifying itself to the RADIUS client.
5. If accounting is also supported by the RADIUS

RADIUS –Advantages and Disadvantage

- **Advantage –**
  - As it is open standard, therefore it can be used between the other devices also.
- **Disadvantage –**
  - As RADIUS uses UDP therefore it is less reliable than TACACS+.
  - No explicit command authorization can be implemented.

REF

- Comptia Security + guide to Network security fundamentals
- https://jumpcloud.com/resources/radius-guide#cookie-accept
- CCNA Security Chapter 7
- Security + guide to network security fundamentals Chapter 10
- Certified ethical hackers foundation guide chapter 6